

Comprehensive Offensive Security Analysis and Report on [REDACTED]

[REDACTED]

Savannah Chappus

November 25, 2024

Comprehensive Offensive Security Analysis and Report on [REDACTED]

Disclaimer 1: *To protect the identity of our client, certain details of this report have been obscured.*

Disclaimer 2: *All of the events discussed in the scope of this report are strictly hypothetical and have not occurred in any form. They are written as if they have happened solely for the purposes of the assignment. Sources that are not explicitly cited in the body of the paper were used for researching the hypothetical scenarios.*

This security report serves as a formal log of the security analysis conducted on [REDACTED] from October 10, 2024 to November 15, 2024. Initially, we had proposed to our client a limited scope analysis such that we could adequately analyze the cyber operations of our client without interfering with their daily operations. Since our client operates in the critical infrastructure sector, minimizing interference with their operations was of the utmost importance in order to maintain the integrity of our client. Our initial proposal included five tests across four categories: 1) social engineering tests, including vishing and phishing simulations; 2) network security tests, such as an external domain review and network traffic monitoring; 3) access control review, including an active directory domain audit; and 4) static analysis, focusing on code and application review. After consulting with our client, we agreed to conduct only the first three test categories, and excluded any static code review from the testing period. The reasons for this were primarily due to time and resource constraints, but we and our client also agreed that the first four tests were more integral to their operations at this time. In addition to conducting a limited scope analysis, we collaborated extensively with our client's executives to design and implement each test. During the testing period, our approach primarily adhered to "white box" principles of offensive security, granting us access to detailed knowledge of the client's infrastructure and internal operations.

Social Engineering Tests

Vishing and Phishing Scam Test

Given the nature of our client, a vishing scam would be the most likely to occur, but for completeness, we tested employees on both vishing and phishing scams. For the purposes of this testing period, we opted to not conduct any smishing scams due in large part to the nature of our client, but we recognize that there may be desire or need for this in the future and have included it in our list of potential future tests, as can be seen in the Future Work section of this paper. In addition, in most social engineering tests, it is in the best interest of the client to test a selected pool of employees who are most at risk of being exploited. Because our client has a small employee base and is less likely to have disgruntled ex-employees, we chose to keep our social engineering tests internal and tested everyone other than those involved in the development of the tests.

Preparation and Setup

For this test, we wrote three scripts to be either read over the phone or sent via email to the selected pool of employees. The first script was adapted for our use from an actual phishing email found and published by Intersys (Philip, 2022). The second and third script were written with feedback from our client. We used a random selection from the three scripts and two formats for each employee in order to ensure a well-defined test. In addition to randomizing our scripts and delivery format, we ensured that we planned our testing at appropriate times and with extensive coordination from the executives so as to not disrupt the operations of our client. The scripts we used can be found below.

Script 1: IT Scam (Email Version).

[Subject: Strange Logon Behavior]

Good morning [REDACTED],

This is the IT department. We received an alert last night informing us of some strange logon behaviour occurring between 12:00 AM and 2:00 AM on your account. We would like you to review the list of locations and devices logged in during that time frame and verify that they all belong to you.

You can access the ticket containing the list below.

[REDACTED]

Script 1: IT Scam (Phone Version).

Good morning [REDACTED],

This is the IT department. We received an alert last night informing us of some strange logon behaviour occurring between 12:00 AM and 2:00 AM on our system. We need to review the list of locations and devices logged in during that time frame to locate the origin of the strange behaviour. Please provide us with your login credentials in order to verify.

Script 2: Credential Request from Phony Executive.

This is [REDACTED]. I am on my way to an emergency meeting and left my access key at home. Can you give me your login credentials so I can quickly pull up [REDACTED]? You can reset your password immediately after if you're concerned.

Script 3: Client Falsely Requesting Services.

[REDACTED]

[REDACTED]

[REDACTED]

[REDACTED]

Note: This script has been kept confidential to protect the integrity of our clients as it contains information pertaining to their specific operations. In brief, the caller pretends to be a client of our client and falsely requests their services in an urgent manner. The idea behind this message would be to distract our client and to divert or strain their resources.

Outcome and Response

By the end of our social engineering tests, we found that 32% of employees fell for one of the scams. Prior to conducting our tests, we had developed a bracketing system that corresponded to specific defense strategies. The results of our test were between 20 and 80 percent, leading us to recommend the following strategy: Given the percentage of employees who fell for the scam, we determined that there is likely some fault in either the employee training or in our client's external risk protection policies. In the latter case, we recommend that our client implement new policies for email and call filtering. Our specific recommendation is to implement new or revised DMARC policies. If instead the issue is resulting from inadequate employee training, we propose an extended training program that would be developed in partnership with our client's executive and would include the following:

- A confidential information overview
- An overview on maintaining integrity
- Fraud identification exercises
- Routine testing (this would continue on a monthly basis until >80% of employees passed the test, at which point we would transition to a new training program)
- A thorough review, analysis, and potential refactoring of company policies on information sharing and distribution

Network Security Tests

External Domain Review

For our first network security test, we conducted an external domain review. We did a brief domain audit on our client's public facing website, but because they don't use it for primary operations, we focused our attention towards their internal domains for our review.

Preparation and Setup

For this test, we began by collecting all of the domains and subdomains associated with our client. We did this in part by consulting with our client, and in part by using Maltego to discover the overall architecture of the domain system of our client. We then designed our tests to follow the framework outlined in the *DNSSEC Infrastructure Audit Framework* by Mekking and Kolkman from the NLnet Labs (2013), which includes, but is not limited to, the following:

- DNSSEC Policy and/or Practice Statement
- Incident Response Procedures
- Geographical Diversity
- Power Continuity
- Trusted Roles
- Secure DNS Instances
- Resource Records Time-to-Live

We only conducted tests from the framework that were in our client's best interest, a decision which was made in consultation with our client's executive. We and our client agreed that the audits proposed in the framework covered all of the current security concerns of our client, so we didn't conduct any tests not covered in the framework. However, we do suggest a few additional tests in the Future Work section of this paper to be conducted in future testing sessions if the need arises.

Outcome and Response

During our testing, we found issues in the following areas:

1. DNSSEC Policy: The entity does not publish a DNSSEC Policy
2. Incident Response Procedures: The client has poorly defined incident response procedures, especially with respect to their DNSSEC operation.
3. Trusted Roles: The client did not specify who is responsible for DNSSEC operations.
4. Secure DNS Instances: The client's policies pertaining to the maintenance of operating systems was unclear and unrefined.

Based on the vulnerabilities identified above, we proposed the following defense strategy to our client:

1. Compose and publish a DNSSEC policy. This can be done in conjunction with us or with an external provider. For an external provider, we suggested that our client follow the instructions in *Creating a DNSSEC Signing Policy* provided by BlueCat because they have a guided online form for creating a DNSSEC signing policy which is straightforward and easily accessible (2024).
2. Outline DNSSEC-specific procedures as they relate to incident response and append them to the client's existing incident response procedures. We worked with our client to draft these procedures based on their needs. This includes, but is not limited to:
 - a. Procedures following a breach of data
 - b. Procedures for recovering compromised data and systems
 - c. Procedures for reporting incidents
3. Designate a specific individual who is responsible for DNSSEC operations. This does not need to be an additional person, but can be added to the duties of an existing employee. In this case, we recommend that the Security Officer (SO) be this individual.

4. Clarify policies for system maintenance. We again worked with the client to create a draft of refined maintenance policies.

Network Traffic Monitoring and Analysis

For our second network security test, we chose to monitor and analyze traffic on our client's network. We chose this test primarily to verify that the network traffic appears as it should be rather than choosing it because we or our client suspect that it could be a weak spot.

Preparation and Setup

For our client's specific use case, we wanted real-time network visualization that was lightweight and non-intrusive. After extensive research, we decided on the use of ntopng for our primary monitoring software, with the addition of Wireshark if deeper analysis was needed. After consulting with our client's executive, we arranged time onsite to install ntopng and Wireshark on their internal network. Next, we established the testing timeline based on the recommendation in the *NIST Computer Security Incident Handling Guide* to require a "baseline level of logging and auditing on all systems" (Cichonski et al., 2012, p.43). Accordingly, we configured ntopng and Wireshark to consume the least amount of resources possible, and conducted a week-long monitoring of our client's system. This method was the most likely to give a high level overview of the usage of the system's resources, including unusual traffic patterns, peak usage times, and other abnormalities. It allowed us to simultaneously develop a baseline for activity and to check for suspicious and anomalous behavior in real-time. During the week of monitoring we checked in on the ntopng results twice per day so that if activity presented that warranted the use of Wireshark, we could proactively start monitoring in Wireshark rather than waiting until the end of the testing.

Outcome and Response

After our week-long investigation of our client's network traffic, we found no serious threats or anomalies in their system. We did however find evidence of some network misconfigurations present in their system, listed below:

- An old printer interface connected to the network was sending frequent update checks, which contributed to unnecessary network chatter.
 - We recommended that our client either update the firmware on the printer or replace it with a newer model to avoid a) extraneous network traffic that could slow response times, and b) attackers leveraging old vulnerabilities to gain access to the system.
- Three unauthorized personal devices were connected to the network.
 - We recommended that our client disconnect all unauthorized devices from the network, implement policies for connecting devices to the network, and enforce consequences for employees who connect unauthorized devices to the network. This is our recommendation because unauthorized personal devices may not mean an employee intends harm to the company, but it provides an access point with different restrictions than the main system, which may allow attackers easier access to the system via the unauthorized device.
- The system's firewall rules were minimal, leading to minimal network segmentation. While this is not an extremely critical misconfiguration, because we noticed it, we suggested the following to our client:
 - As is suggested by a joint NSA and CISA report on common network misconfigurations, we suggest implementing "next-generation firewalls to perform deep packet filtering, stateful inspection, and application-level packet inspection" (2023).

Access Control Review

Active Directory Domain Audit

For this test, we implemented an active directory domain audit. We chose this test as our client's operations occur primarily within their internal systems, so ensuring that those systems are properly configured and secure is important to their continued operations. For this audit, we and our client agreed that the best method of testing was to implement an initial review of the active directory structure, and fix any issues we find along the way, repeating the process as needed. We opted to not simulate any attacks from either internal or external attackers at this time, but did recommend it in the Future Work section of this report.

Preparation and Setup

We opted for a manual review of our clients active directory domains rather than relying on an external service. We used a combination of tools including, but not limited to Nmap, OpenLDAP, Wireshark, general CLI commands, and BloodHound to conduct our testing. In addition to performing our review manually, we closely followed the guidelines set forth by the *Assessment of Access Control Systems* and the *Guidelines for Access Control System Evaluation Metrics* during the process (Hu et al., 2006; Hu & Scarfone, 2012). We did any necessary installations as we went, so we could avoid straining our client's system in an extraneous ways (ie. if an install wasn't used, or we chose to install too many things at once).

Outcome and Response

In our review of our client's active directory domains, we found the following issues:

1. Several counts of improper user/administrator privilege separation including the following:
 - a. One account with excessive privileges.
 - i. Our suggestion: Remove any unnecessary privileges from this account.

- b. Two occurrences of regular use of an elevated account for non-essential purposes
 - i. Our suggestion: only use accounts with elevated privileges for elevated uses to avoid “increas[ing] the account’s exposure and, therefore, its risk of compromise and its risk to the network.” (*NSA and CISA*, 2023).
- c. One account with elevated access privileges that was no longer used or monitored.
 - i. Our suggestion: remove the unused account from the domain.
Additionally, we recommend that our client schedule regular checks for inactive user accounts on a frequency that we leave to their discretion.
- 2. Six easily crackable passwords
 - a. We suggested that the employees associated with the weak passwords change their passwords to stronger ones and that our client implement a stricter password policy.
- 3. Four additional passwords found in security breaches
 - a. We suggested that our client have the employees with breached passwords change them, monitor the associated accounts for suspicious activity for a minimum of one month, and implement password expiration policies to account for leaked passwords.
- 4. Two shared accounts with no password set
 - a. We suggest setting a strong password even on shared accounts.
- 5. One instance of a service with out-of-the-box security settings. After reviewing the security settings of this service with our client, we agreed that the settings were inadequate for our client’s system and needed to be updated.
 - a. Our recommendation was to update the security settings for the service to better suit our client’s needs.

In addition to the specific suggestions following the events above, we also recommended the use of Wazuh to our client for several reasons. First, Wazuh is free and open source, which makes it a desirable low-budget solution. Second, because Wazuh is a Security Information and Event Management (SIEM) tool, our client can now have regular monitoring of their internal hosts in order to more proactively catch potential security flaws. Especially in the critical infrastructure sector, proactive methods are far superior to reactive methods.

Future Work and Conclusion

Security is an ongoing process. We acknowledge that our client may desire additional testing, either to follow up on results from the tests covered in this report, or to test for new security issues. We have included this section as a starting point for future testing with this client. What follows is a noncomprehensive list of potential future security tests for our client.

- Static code and application analysis
- Smishing scams
- Attack simulations to test the new implementations in the system
- Man-In-The-Middle (MITM) attacks (Mekking & Kolkman, 2013)
- Denial of service attacks (Mekking & Kolkman, 2013)
- Physical access control review (Mekking & Kolkman, 2013)

In addition to the specific suggestions listed above, we also note that all of the tests conducted during our review have the opportunity for continued and follow-up testing. Our testing period was intended to be a starting point for our client to improve on their security measures and we expect that more testing will be desired by our client in the future.

References

- Bertucci, D. (2024, November 4). *Network traffic monitoring in 2024: Discover the top 7 solutions*. Auvik. <https://www.auvik.com/franklyit/blog/best-network-traffic-monitor/>
- Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer Security Incident Handling Guide : Recommendations of the National Institute of Standards and Technology*. <https://doi.org/10.6028/nist.sp.800-61r2>
- Creating a DNSSEC signing policy*. Address Manager Administration Guide. (2024). <https://docs.bluecatnetworks.com/r/Address-Manager-Administration-Guide/DNSSEC-with-Address-Manager-and-DNS/DHCP-Server/9.3.0>
- Firch, J. (2024, February 28). *Social engineering penetration testing: Attacks, methods, & steps*. PurpleSec. <https://purplesec.us/learn/social-engineering-penetration-testing/>
- Hu, V. C., & Scarfone, K. (2012). *Guidelines for Access Control System Evaluation Metrics*. <https://doi.org/10.6028/nist.ir.7874>
- Hu, V. C., Ferraiolo, D. F., & Kuhn, D. R. (2006). *Assessment of Access Control Systems*. <https://doi.org/10.6028/nist.ir.7316>
- Mekking, M., & Kolkman, O. (2013). (rep.). *DNSSEC Infrastructure Audit Framework*. Retrieved November 15, 2024, from <https://www.nlnetlabs.nl/downloads/publications/dns-audit-framework-1.0.pdf>.
- NSA and CISA Red and Blue Teams Share Top Ten Cybersecurity Misconfigurations*. Cybersecurity and Infrastructure Security Agency CISA. (2023, October 5). <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-278a>

Philp, M. (2022, August 4). *10 phishing email examples and why we know they're fake*. Intersys.

<https://intersys.co.uk/2022/08/04/10-phishing-email-examples-and-why-we-know-theyre-fake/>

What are DMARC, DKIM, and SPF?. Cloudflare. (2024).

<https://www.cloudflare.com/learning/email-security/dmarc-dkim-spf/>

Yakushkin, V. (2024, March 22). *Active directory (AD) auditing: Security Tips & Best Practices*.

Syteca. <https://www.syteca.com/en/blog/secure-active-directory-with-pam>